

WORKSHOP ÉVALUÉ : INGÉNIERIE DE L'OBSERVABILITÉ SÉCURISÉE

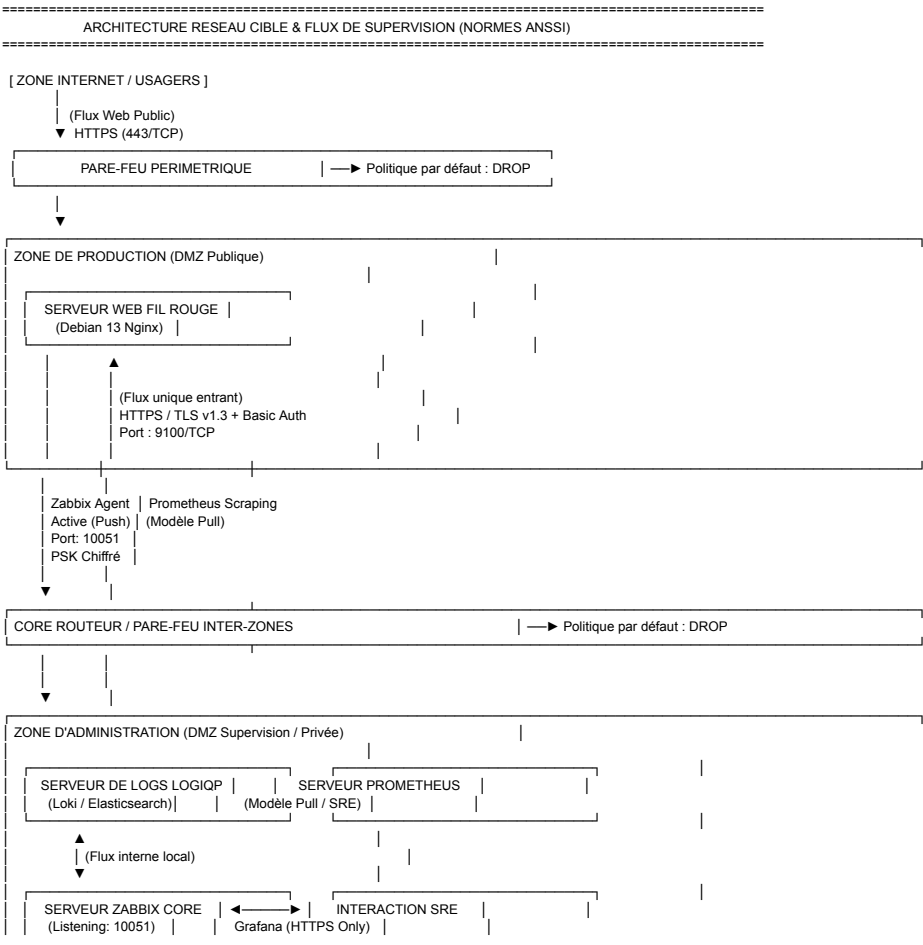
1. Périmètre et Objectifs du Projet

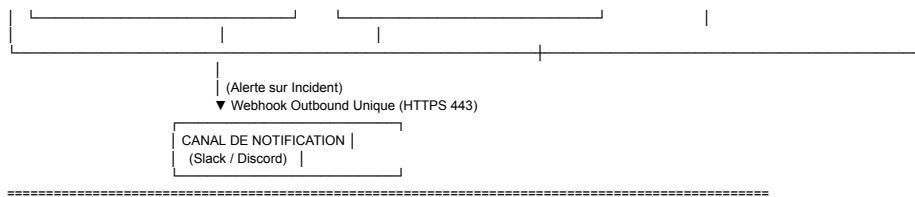
La société **M2-Shop** (plateforme de commerce électronique) souhaite refondre complètement sa stratégie d'observabilité. Suite à un audit de sécurité récent, l'ANSSI a pointé du doigt la porosité de l'ancienne infrastructure de supervision.

Votre mission est de concevoir et déployer une **plateforme d'observabilité centralisée et durcie**, capable d'absorber les métriques et les logs de la zone de production tout en garantissant un cloisonnement strict des réseaux d'administration.

2. Spécifications Techniques Détaillées

Vous disposez d'un hyperviseur (Proxmox VE ou d'un cluster Docker) pour instancier les machines virtuelles / conteneurs nécessaires. L'ensemble des systèmes d'exploitation devra s'appuyer sur des distributions stables (**Debian 13** recommandée).





Jalon A : Cloisonnement et Filtrage Réseau

Vous devez configurer le pare-feu (**nftables** ou **iptables**) sur chaque zone pour implémenter un modèle de sécurité à confiance zéro (*Zero-Trust*).

- **Politique par défaut** : Appliquez la règle **DROP** en entrée (**INPUT**) et en sortie (**OUTPUT**) sur toutes les machines.
- **Flux Applicatifs** : Le serveur Web en production n'autorise que les flux HTTP/HTTPS légitimes.
- **Flux de Supervision** :
 - **Zabbix Agent** : Doit fonctionner exclusivement en mode **Actif (Push)**. L'agent de production initie la connexion vers le serveur Zabbix (Port **10051/TCP**). Aucun flux entrant venant du serveur Zabbix n'est autorisé en production.
 - **Prometheus** : Fonctionne en mode **Pull**. Le serveur Prometheus est le seul autorisé à initier une connexion vers la zone de production sur le port du Node Exporter (**9100/TCP**).

Jalon B : Durcissement et Chiffrement des Collecteurs

Toutes les données d'administration transitant sur le réseau doivent être protégées en intégrité et en confidentialité.

- **Sécurisation de Prometheus (Node Exporter)** : Vous devez générer un certificat TLS auto-signé pour le Node Exporter de production. Configurez le fichier **web-config.yml** de l'exporter pour :
 1. Forcer l'utilisation de **TLS v1.3**.
 2. Activer une **Authentification Basique** (générer un mot de passe haché par l'outil **bcrypt**).
 3. Côté serveur, configurez le **prometheus.yml** avec les directives **scheme: https, tls_config** (insecure_skip_verify si auto-signé) et **basic_auth**.
- **Sécurisation de Zabbix** : Générez une clé pré-partagée (**PSK**) de minimum 64 caractères hexadécimaux. Configurez l'agent Zabbix et l'hôte sur l'interface serveur pour chiffrer les communications via cette PSK.

Jalon C : Centralisation des Logs et Dashboarding

L'objectif est d'unifier la vision de l'ingénieur SRE sur une seule interface.

- **Ingestion des Logs** : Déployez un agent de collecte de logs (Promtail ou Filebeat) sur le serveur Web de production. Configurez-le pour surveiller `/var/log/nginx/access.log` et `/var/log/nginx/error.log`. Ces logs doivent être poussés vers votre collecteur central (Loki ou Elasticsearch).
- **Interface de Restitution (Grafana)** :
 - L'interface doit être exposée uniquement en **HTTPS**.
 - Créez un tableau de bord unifié combinant : l'état des ressources système (Zabbix/Prometheus) et l'analyse de la santé applicative (Loki/ELK).
 - Le dashboard doit mettre en évidence le taux d'erreurs HTTP (4xx et 5xx) ainsi que le volume de requêtes par seconde.

Jalon D : Alerting et Remédiation Automatique Durcie

- **Routage des alertes** : Configurez une alerte lorsque le service Nginx ne répond plus. Cette alerte doit être envoyée en moins de 60 secondes vers un webhook (Slack ou Discord) avec un message formaté indiquant l'heure, l'hôte et l'impact.
- **Script d'Auto-Healing** : Écrivez un script de remédiation (Bash ou Python) qui s'exécute automatiquement lors de la détection de l'incident pour relancer le service.
- **Contrainte de Sécurité Sudoers** : Le compte de l'agent de supervision exécutant le script de remédiation ne doit pas être `root`. Vous devez configurer le fichier `/etc/sudoers.d/supervision` de manière chirurgicale :

3. Structure Attendue du Dossier Technique

Le **Dossier d'Architecture et d'Exploitation (DAE)** doit être déposé au format PDF avant 17h00 le deuxième jour. Un document standardisé et professionnel est exigé.

- **Section 1 : Architecture Réseau (DAT)**
 - Schéma détaillé des zones réseau (Prod, Admin) avec positionnement des composants.

○ **Matrice de Flux réglementaire :**

Zone Source	IP Source	Zone Dest.	IP Dest.	Protocole	Port	Justification
DMZ Admin	10.0.10.5	DMZ Prod	10.0.20.20	TCP	9100	Scraping Prometheus TLS/Auth

○

Section 2 : Dossier d'Exploitation (DEX)

- Code source commenté du script de remédiation automatique.
- Configuration des règles de filtrage de chaque machine.
- Preuves de chiffrement (Sortie de commande `ss -tln` ou capture de certificats).

- **Section 3 : Plan de Continuité Opérationnelle**
 - Procédure pas-à-pas d'isolation d'un serveur web compromis (confinement réseau d'urgence).
 - Template vierge de rapport **Post-Mortem** d'incident.

4. Protocole de Recette Technique

1. **Audit des flux** : Le formateur tentera de joindre le serveur de supervision depuis la machine de production en dehors des ports explicitement autorisés. Le flux doit expirer (*Timeout / Dropped*).
2. **Audit du chiffrement** : Un `curl -k https://[IP_PROD]:9100/metrics` sans identifiants doit retourner une erreur `401 Unauthorized`.
3. **Crash Test & Auto-Healing** : Le formateur exécutera un `sudo systemctl stop nginx` sur le serveur de production.
 - *Attendu* : L'alerte doit s'afficher sur le canal de communication de l'équipe. Le service Nginx doit se relancer automatiquement dans la minute. Le formateur vérifiera que le script a été exécuté sans élévation `root` globale.